

Título del trabajo: Seguridad de la información Unidad 2

Carrera: Ingeniería en ciberseguridad
Asignatura: Fundamentos de seguridad de la información

Profesor: Saul Ortega
Fecha de envío: 02/12/2024
Nombre(s) de estudiante(s):
Javier Cerda
Ignacio Silva
Cristofer Calfin Urrea

1.Introducción:

En el presente informe, se abarcarán los contenidos tratados en la unidad número 2 de esta asignatura. Entre los tópicos de relevancia, tenemos como tema principal el escaneo de redes y detección de vulnerabilidades, dicha temática será abordada mediante diversas herramientas que serán puestas en práctica para evidenciar los contenidos aprendidos en clases, en base a casos proporcionados para el desarrollo de la actividad, que provienen de metasploitable y Juice shop.

Actividad 1.

NMAP

Para introducirnos en el mundo del escaneo activo con la herramienta nmap, procederemos a detallar el uso y que es esta herramienta, según el siguiente autor nos describe lo siguiente: “Nmap es una herramienta de código abierto utilizada para el descubrimiento y la auditoria de seguridad de redes” (Lyon, G, 2009) *Nmap Network Scanning*.

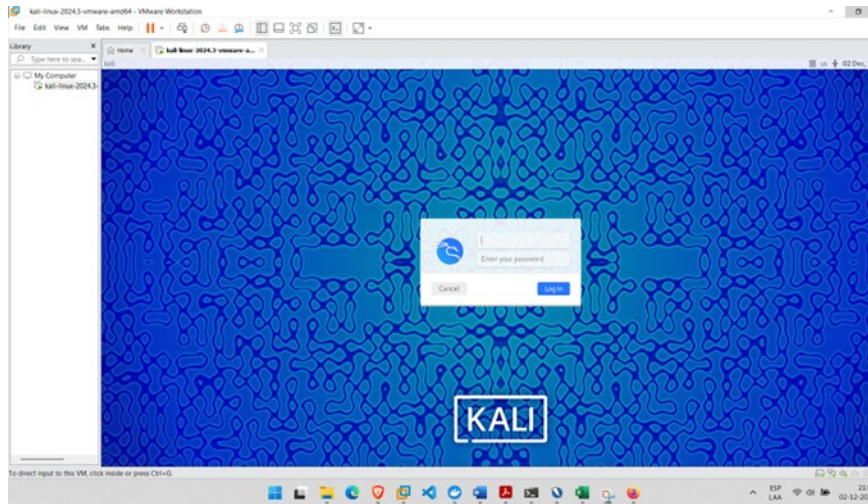
Esta herramienta permite identificar que dispositivos están conectados a una red, el tipo de servicio que están ofreciendo, el tipo de sistema operativo que están ejecutando, entre otros detalles, esta herramienta es fundamental en el mundo de la ciberseguridad, esto se debe a la gran capacidad de proporcionar información en detalle y de gran utilidad.

Dentro de las principales características tenemos las siguientes:

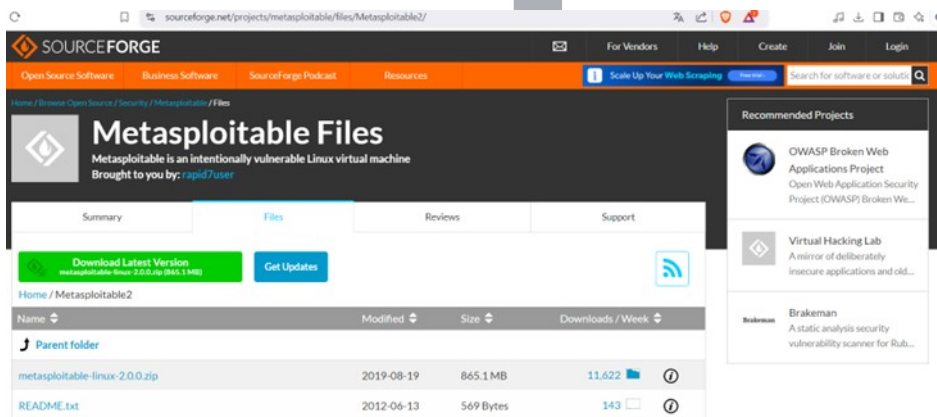
- Escaneo de puertos: la cual identifica puertos que puedan estar abiertos en ciertos dispositivos de red.
- Detección de sistemas operativos: el cual puede obtener información de que sistema operativo se está ejecutando en un dispositivo verificando las características de los paquetes de red.
- Detección de versiones de servicios: con esto obtenemos las versiones específicas de los servicios que se pueden estar ejecutando.
- Escaneo de red completa: se puede escanear la red completa en búsqueda de dispositivos activos y verificar que servicios tiene.
- Escaneos sigilosos: puede ejecutar escaneos sin detección por el target.

Entorno de laboratorio

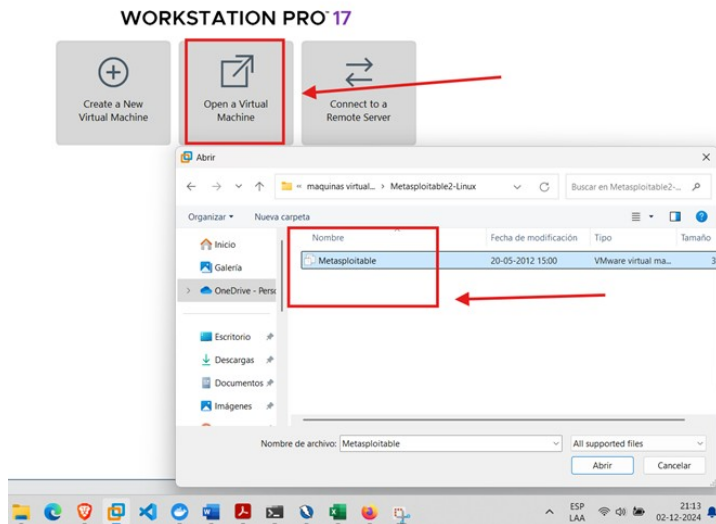
Procederemos a abrir nuestra máquina virtual Kali Linux, con la cual procederemos a utilizar la herramienta NMAP.



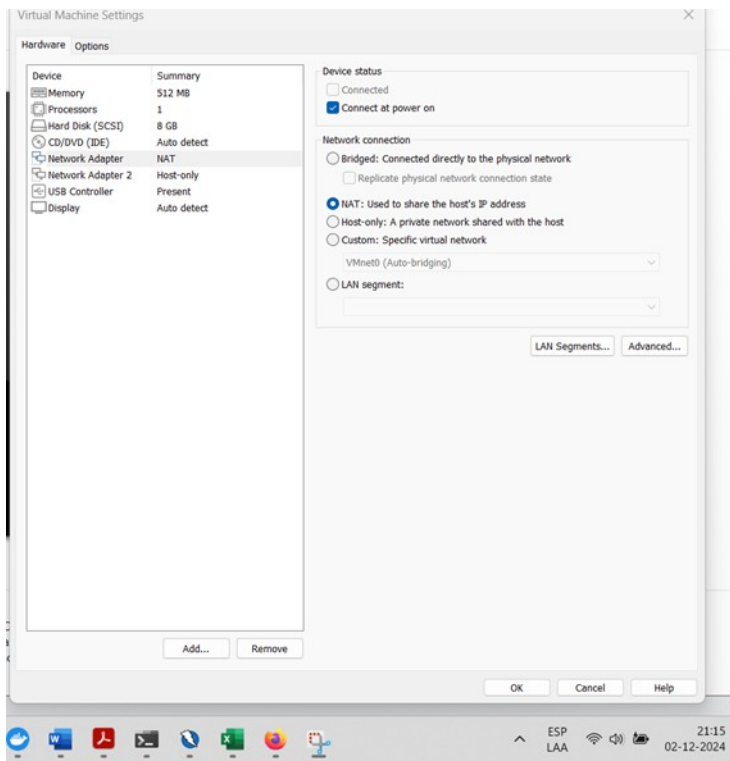
Descargaremos “Metasploitable2” el cual será nuestro objetivo durante los escaneos a realizar, para esto utilizaremos la fuente entregada “<https://sourceforge.net/projects/metasploitable/files/Metasploitable2/>”.



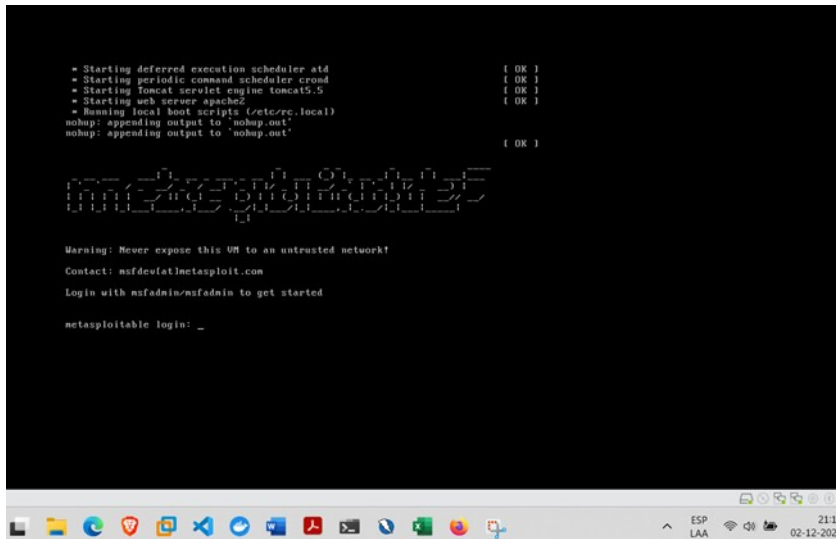
Seguido de la descarga de la imagen, procedemos a abrirla y virtualizar Metasploitable2.



Mediante la configuración predeterminada procedemos a guardar y dejar la conexión de red en NAT, en este caso vamos a solamente atacar a Metasploitable2, entregando seguridad a nuestro laboratorio.

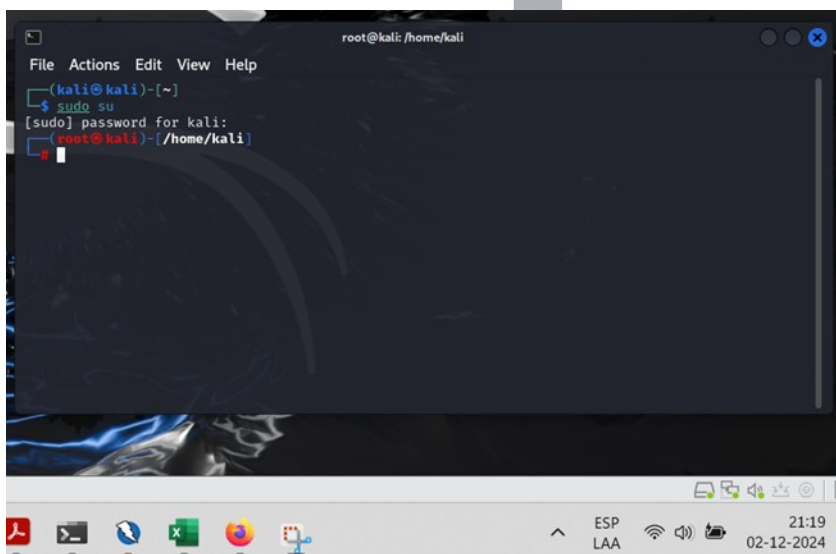


Revisamos la virtualización de Metasploitable, en donde debemos dejar la máquina virtual de esta manera.



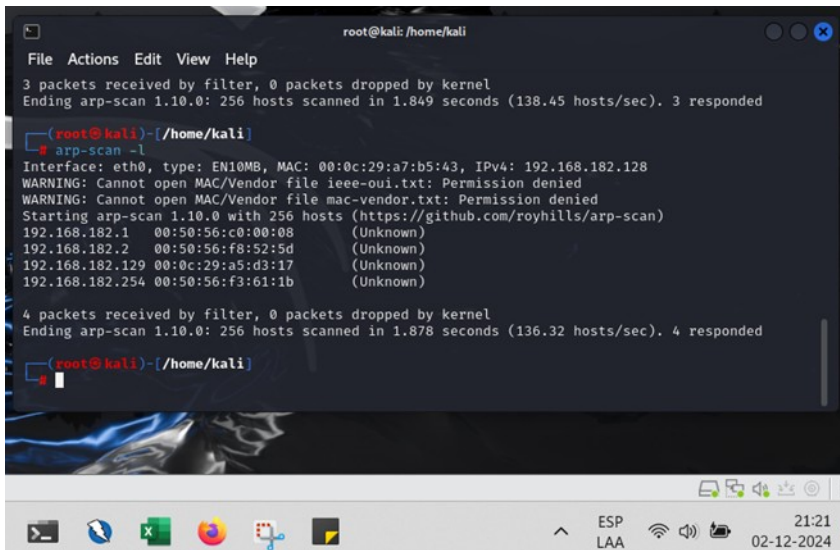
A screenshot of a terminal window showing the boot process of a Metasploitable virtual machine. The text includes: "Starting deferred execution scheduler atd [OK]", "Starting periodic command scheduler crond [OK]", "Starting Tomcat servlet engine tomcat5.5 [OK]", "Starting web server apache2 [OK]", "Running local boot scripts (/etc/rc.local)", "msfdev: appending output to 'msfdev.out'", and "msfdev: appending output to 'msfdev.out' [OK]". Below this is a large ASCII art logo for Metasploit. Further down, it says "Warning: Never expose this VM to an untrusted network!", "Contact: msfdev@metasploit.com", "Login with msfadmin/msfadmin to get started", and "metasploitable login: _". The terminal is running on a desktop environment with a taskbar at the bottom showing various application icons and system status indicators like "ESP LAA", "21:17", and "02-12-2024".

Ingresamos como usuario root a nuestro Kali Linux para proceder a realizar el escaneo con NMAP.



A screenshot of a Kali Linux terminal window. The prompt is "root@kali: /home/kali". The user has entered "sudo su" and the prompt has changed to "root@kali: /home/kali". The terminal shows the command history and the current command being entered. The desktop environment is visible in the background, with a taskbar at the bottom showing application icons and system status indicators like "ESP LAA", "21:19", and "02-12-2024".

Identificamos la dirección IP de nuestro objetivo, la cual en esta ocasión es la IP 192.168.182.129, ahora podremos comenzar a realizar el escaneo con nmap, para realizar este tipo de escaneo utilizaremos el comando “nmap” seguido de la dirección IP objetivo, luego iremos utilizando otros comandos para obtener más información.



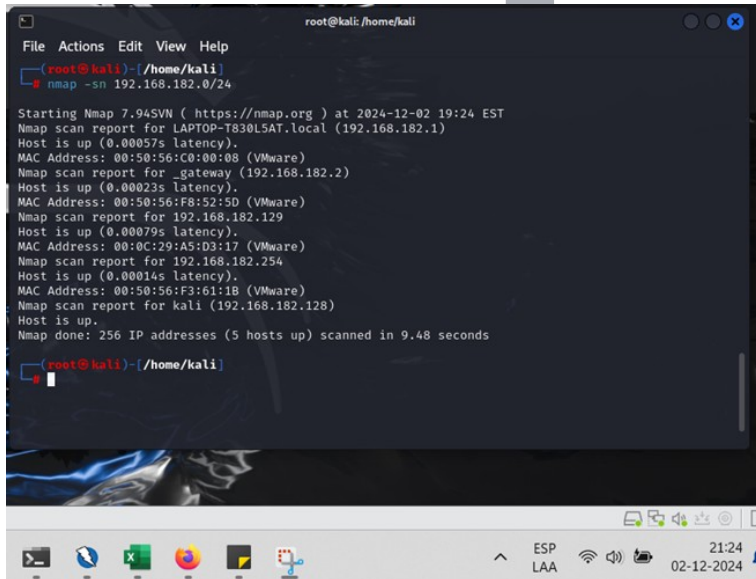
```
root@kali: /home/kali
File Actions Edit View Help
3 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.849 seconds (138.45 hosts/sec). 3 responded

root@kali)~[/home/kali]
# arp-scan -l
Interface: eth0, type: EN10MB, MAC: 00:0c:29:a7:b5:43, IPv4: 192.168.182.128
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.182.1 00:50:56:c0:00:08 (Unknown)
192.168.182.2 00:50:56:f8:52:5d (Unknown)
192.168.182.129 00:0c:29:a5:d3:17 (Unknown)
192.168.182.254 00:50:56:f3:61:1b (Unknown)

4 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.878 seconds (136.32 hosts/sec). 4 responded

root@kali)~[/home/kali]
```

Realizamos un escaneo de host, esto agregando a el comando “-sn” realizando un escaneo de tipo ping.



```
root@kali: /home/kali
File Actions Edit View Help
root@kali)~[/home/kali]
# nmap -sn 192.168.182.0/24

Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-12-02 19:24 EST
Nmap scan report for LAPTOP-T830L5AT.local (192.168.182.1)
Host is up (0.00057s latency).
MAC Address: 00:50:56:C0:00:08 (VMware)
Nmap scan report for _gateway (192.168.182.2)
Host is up (0.00023s latency).
MAC Address: 00:50:56:F8:52:5D (VMware)
Nmap scan report for 192.168.182.129
Host is up (0.00079s latency).
MAC Address: 00:0C:29:A5:D3:17 (VMware)
Nmap scan report for 192.168.182.254
Host is up (0.00014s latency).
MAC Address: 00:50:56:F3:61:1B (VMware)
Nmap scan report for kali (192.168.182.128)
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 9.48 seconds

root@kali)~[/home/kali]
```




UNIVERSIDAD
MAYOR

para espíritus emprendedores

Procedemos a realizar un escaneo de puertos, en donde con “-p 1-65535” especificamos que nmap realice un escaneo a todos los puertos conocidos desde el puerto 1 al puerto 65535.

```
root@kali: /home/kali
File Actions Edit View Help
root@kali: /home/kali
$ nmap -p 1-65535 192.168.182.129

Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-12-02 19:26 EST
Nmap scan report for 192.168.182.129
Host is up (0.0017s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1009/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
3632/tcp  open  distcc
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
6697/tcp  open  ircs-u
8009/tcp  open  ajp13
8180/tcp  open  unknown
8787/tcp  open  msgsrvr
41421/tcp open  unknown
41932/tcp open  unknown
43364/tcp open  unknown
43691/tcp open  unknown
MAC Address: 00:0C:29:A5:D3:17 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 11.93 seconds
```

Ahora realizaremos un escaneo a los servicios activos del objetivo, al comando nmap le agregaremos “-sV” para indicarle a la herramienta que detecte las versiones de los servicios.

```
root@kali: /home/kali
File Actions Edit View Help
Nmap done: 1 IP address (1 host up) scanned in 11.93 seconds
root@kali: /home/kali
$ nmap -sV 192.168.182.129

Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-12-02 19:29 EST
Nmap scan report for 192.168.182.129
Host is up (0.00075s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
53/tcp    open  domain         ISC BIND 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind        2 (RPC #100000)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec           netkit-rsh rexecd
513/tcp   open  login          OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1009/tcp  open  java-remote    GNU Classpath gmiiregistry
1524/tcp  open  bindshell      Metasploitable root shell
2049/tcp  open  nfs            2-4 (RPC #100003)
2121/tcp  open  ftp            ProFTPD 1.3.1
3306/tcp  open  mysql          MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql     PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc            VNC (protocol 3.3)
6000/tcp  open  X11            (access denied)
6667/tcp  open  irc            UnrealIRCd
6697/tcp  open  irc            Apache Jserv (Protocol v1.3)
8009/tcp  open  ajp13          Apache Tomcat/Coyote JSP engine 1.1
8180/tcp  open  http           Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:A5:D3:17 (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 19.23 seconds
root@kali: /home/kali
```




Ahora nos queda realizar un escaneo de vulnerabilidades de nuestro objetivo, la cual nos entrega las siguientes vulnerabilidades.

- | | PORT | STATE | SERVICE |
|----|----------------------------------|-------|---------|
| | 21/tcp | open | ftp |
| | ftp-vsftpd-backdoor: | | |
| | VULNERABLE: | | |
| | vsFTPD version 2.3.4 backdoor | | |
| | State: VULNERABLE (Exploitable) | | |
| 1. | IDs: CVE:CVE-2011-2523 BID:48539 | | |
-
- | | | | |
|----|----------------------------------|------|-----|
| | 21/tcp | open | ftp |
| | ftp-vsftpd-backdoor: | | |
| | VULNERABLE: | | |
| | vsFTPD version 2.3.4 backdoor | | |
| | State: VULNERABLE (Exploitable) | | |
| 2. | IDs: CVE:CVE-2011-2523 BID:48539 | | |

22/tcp open ssh

23/tcp open telnet

25/tcp open smtp

| ssl-poodle:

| VULNERABLE:

| SSL POODLE information leak

| State

: VULNERABLE

| IDs: CVE:CVE-2014-3566 BID:70574

3.

| Anonymous Diffie-Hellman Key Exchange MitM Vulnerability

| **State:** VULNERABLE

| Transport Layer Security (TLS) services that use anonymous

| Diffie-Hellman key exchange only provide protection against passive

| eavesdropping, and are vulnerable to active man-in-the-middle attacks

| which could completely compromise the confidentiality and integrity

| of any data exchanged over the resulting session.

4.

5.

| Transport Layer Security (TLS) Protocol DHE_EXPORT Ciphers Downgrade MitM (Logjam)

| **State:** VULNERABLE

| IDs: CVE:CVE-2015-4000 BID:74733

- | Diffie-Hellman Key Exchange Insufficient Group Strength
 - | **State:** VULNERABLE
 - | Transport Layer Security (TLS) services that use Diffie-Hellman groups
 - | of insufficient strength, especially those using one of a few commonly
 - | shared groups, may be susceptible to passive eavesdropping attacks.
- 6.
- 7.
- | Slowloris DOS attack
 - | **State:** LIKELY VULNERABLE
 - | IDs: CVE:CVE-2007-6750
 - | Slowloris tries to keep many connections to the target web server open and hold
 - | them open as long as possible. It accomplishes this by opening connections to
 - | the target web server and sending a partial request. By doing so, it starves
 - | the http server's resources causing Denial Of Service.
- 8.
- | RMI registry default configuration remote code execution vulnerability
 - | **State:** VULNERABLE
 - | Default configuration of RMI registry allows loading classes from remote URLs which
 - | can lead to remote code execution.
- 9.
- | Diffie-Hellman Key Exchange Insufficient Group Strength
 - | **State:** VULNERABLE
 - | Transport Layer Security (TLS) services that use Diffie-Hellman groups
 - | of insufficient strength, especially those using one of a few commonly
 - | shared groups, may be susceptible to passive eavesdropping attacks.

- | SSL/TLS MITM vulnerability (CCS Injection)
 - | **State:** VULNERABLE
 - | Risk factor: High
 - | OpenSSL before 0.9.8za, 1.0.0 before 1.0.0m, and 1.0.1 before 1.0.1h
 - | does not properly restrict processing of ChangeCipherSpec messages,
 - | which allows man-in-the-middle attackers to trigger use of a zero
 - | length master key in certain OpenSSL-to-OpenSSL communications, and
 - | consequently hijack sessions or obtain sensitive information, via
 - | a crafted TLS handshake, aka the "CCS Injection" vulnerability.
- 10.
- | SSL POODLE information leak
 - | **State:** VULNERABLE
 - | IDs: CVE:CVE-2014-3566 BID:70574
- 11.

Análisis vulnerabilidades o riesgos

Escaneo de host: dentro de las posibles vulnerabilidades o riesgos de este primer escaneo tenemos los siguientes.

- Dispositivos desconocidos: los cuales no deberían encontrarse en la red, esto podría generar accesos no autorizados
- Virtualización: se recomienda proteger el entorno virtual para que no tenga posibles ataques internos, de esta manera asegurar que las máquinas virtuales se encuentren aisladas y protegidas.

Escaneo de puertos y servicios: para esto analizamos el escaneo realizado y podemos observar que se han detectado varios puertos abiertos, los cuales tienen su propia descripción teniendo puertos inseguros o críticos y puertos desconocidos, de igual manera nos muestra los servicios que en este caso de verían comprometidos o vulnerables, como se detalla en la siguiente tabla:

Puerto	Estado	Servicio	Descripción	Riesgo
21/tcp	Open	FTP	Protocolo para transferencia de archivos	Si permite acceso anónimo o usa credenciales débiles, puede ser explotado
22/tcp	Open	SSH	Protocolo seguro para administración remota	Si usa claves débiles o no está configurado correctamente , puede ser atacado mediante fuerza bruta
23/tcp	Open	Telnet	Protocolo de administración remota (no	Vulnerable al espionaje de



			cifrado)	credenciales (no usa cifrado)
25/tcp	Open	SMTP	Protocolo para envío de correos electrónicos	Puede ser usado para envío de correos SPAM si no está configurado correctamente
80/tcp	Open	HTTP	Protocolo web	Si la aplicación tiene vulnerabilidades (XSS, SQLi), puede ser explotada
3306/tcp	Open	MySQL	Base de datos MySQL	Acceso no autorizado o credenciales débiles podrían comprometer la base de



				datos
5432/tcp	Open	PostgreSQL	Base de datos PostgreSQL	Riesgos similares a MySQL
5900/tcp	Open	VNC	Protocolo para acceso remoto gráfico	Si está mal configurado o no usa contraseñas fuertes, permite acceso remoto no autorizado
6667/tcp	Open	IRC	Protocolo de chat	Puede ser usado para C and C (comando y control) en botnets si está comprometido
Varios	Open	Puertos desconoci	Servicios no identificados	Podrían corresponder a servicios

		dos (varios como 43691, 44364)		personalizados o malware en ejecución. Es necesario investigar más a fondo.
--	--	--	--	--

El ultimo escaneo solicitado, fue el escaneo de vulnerabilidades las cuales podemos separar las vulnerabilidades encontradas, se detallarán los resultados como sigue:

1. Esta vulnerabilidad permite a una puerta trasera.

```
PORT STATE SERVICE
21/tcp open ftp
| ftp-vsftpd-backdoor:
| VULNERABLE:
| vsFTPD version 2.3.4 backdoor
| State: VULNERABLE (Exploitable)
| IDs: CVE:CVE-2011-2523 BID:48539
```

2. Esta vulnerabilidad permite ataques de man in the middle.

```
22/tcp open ssh
23/tcp open telnet
25/tcp open smtp
| ssl-poodle:
| VULNERABLE:
| SSL POODLE information leak
| State
: VULNERABLE
| IDs: CVE:CVE-2014-3566 BID:70574
```

3. Esta vulnerabilidad se refiere a una falla en el protocolo de intercambio de claves

- | Anonymous Diffie-Hellman Key Exchange MitM Vulnerability
- | **State:** VULNERABLE
- | Transport Layer Security (TLS) services that use anonymous
- | Diffie-Hellman key exchange only provide protection against passive
- | eavesdropping, and are vulnerable to active man-in-the-middle attacks
- | which could completely compromise the confidentiality and integrity
- | of any data exchanged over the resulting session.

4. Esta vulnerabilidad afecta al protocolo TLS al utilizar cifrado DHE_EXPORT.

- | Transport Layer Security (TLS) Protocol DHE_EXPORT Ciphers Downgrade MitM (Logjam)
- | **State:** VULNERABLE
- | IDs: [CVE:CVE-2015-4000](#) [BID:74733](#)

5. Esta vulnerabilidad puede lograr que un atacante pueda interceptar y decifrar la comunicación.

- | Diffie-Hellman Key Exchange Insufficient Group Strength
- | **State:** VULNERABLE
- | Transport Layer Security (TLS) services that use Diffie-Hellman groups
- | of insufficient strength, especially those using one of a few commonly
- | shared groups, may be susceptible to passive eavesdropping attacks.

6. Esta vulnerabilidad afecta a la denegación de servicio DoS.

- | [Slowloris](#) DOS attack
- | **State:** LIKELY VULNERABLE
- | IDs: [CVE:CVE-2007-6750](#)
- | [Slowloris](#) tries to keep many connections to the target web server open and hold
- | them open as long as possible. It accomplishes this by opening connections to
- | the target web server and sending a partial request. By doing so, it starves
- | the http server's resources causing Denial Of Service.

7. Esta vulnerabilidad permite cargas maliciosas desde URL remotas.

- | RMI registry default configuration remote code execution vulnerability
- | **State:** VULNERABLE
- | Default configuration of RMI registry allows loading classes from remote URLs which can lead to remote code execution.

8. Esta vulnerabilidad puede ser explotada con ataques de espionaje pasivo.

- | Diffie-Hellman Key Exchange Insufficient Group Strength
- | **State:** VULNERABLE
- | Transport Layer Security (TLS) services that use Diffie-Hellman groups
- | of insufficient strength, especially those using one of a few commonly
- | shared groups, may be susceptible to passive eavesdropping attacks.

9. Esta vulnerabilidad puede sufrir ataque de inyección y hombre en el medio MitM.

- | SSL/TLS MITM vulnerability (CCS Injection)
- | **State:** VULNERABLE
- | Risk factor: High
- | OpenSSL before 0.9.8za, 1.0.0 before 1.0.0m, and 1.0.1 before 1.0.1h
- | does not properly restrict processing of ChangeCipherSpec messages,
- | which allows man-in-the-middle attackers to trigger use of a zero
- | length master key in certain OpenSSL-to-OpenSSL communications, and
- | consequently hijack sessions or obtain sensitive information, via
- | a crafted TLS handshake, aka the "CCS Injection" vulnerability.

10. Esta vulnerabilidad permite a un atacante MitM la obtención de texto en claro.

- | SSL POODLE information leak
- | **State:** VULNERABLE
- | IDs: [CVE:CVE-2014-3566](#) [BID:70574](#)

Como parte de las recomendaciones a los tipos de escaneos que pudimos realizar con NMAP, logramos identificar mucha información valiosa al momento de realizar auditorías por ejemplo, esto siempre debe realizarse con la autorización de la organización a auditar ya que podría generar o afectar las normas legales vigentes, dentro de las recomendaciones siempre debemos actualizar y parchar nuestros sistemas, de igual manera debemos brindar una correcta seguridad a nuestra red, el monitoreo siempre debe ser continuo y conforme a lo reglamentario, y dentro de todo siempre estar en constante actualización, ya que, los atacantes a nivel mundial se encuentran a la vanguardia en este tipo de herramientas y acciones, en donde como atacantes esperan encontrar la más mínima vulnerabilidad para poder ingresar y acceder a nuestros sistemas para generar algún tipo de daño.

Actividad 2.

¿Qué es Nessus?

Nessus es un escáner de vulnerabilidades muy utilizado en ciberseguridad, este fue desarrollado por Tenable y permite identificar configuraciones erróneas, vulnerabilidades conocidas y debilidades en sistemas y redes. Es una herramienta importante para los profesionales de ciberseguridad, ya que ayuda a fortalecer la seguridad en los sistemas.

Características de Nessus:

- Detecta vulnerabilidades, configuraciones débiles y parches faltantes.
- Compatible con una gran variedad de sistemas operativos y dispositivos.
- Genera informes detallados para priorizar y solucionar incidencias.
- Ofrece una versión de prueba gratuita y de pago con más funcionalidades.

Instalación de Nessus en Kali Linux.

1. Requisitos previos.
2. Tener privilegios de administrador en el sistema operativo.
3. Conexión a internet estable.
4. Espacio suficiente en disco de al menos 2 GB.

Pasos para instalar Nessus:

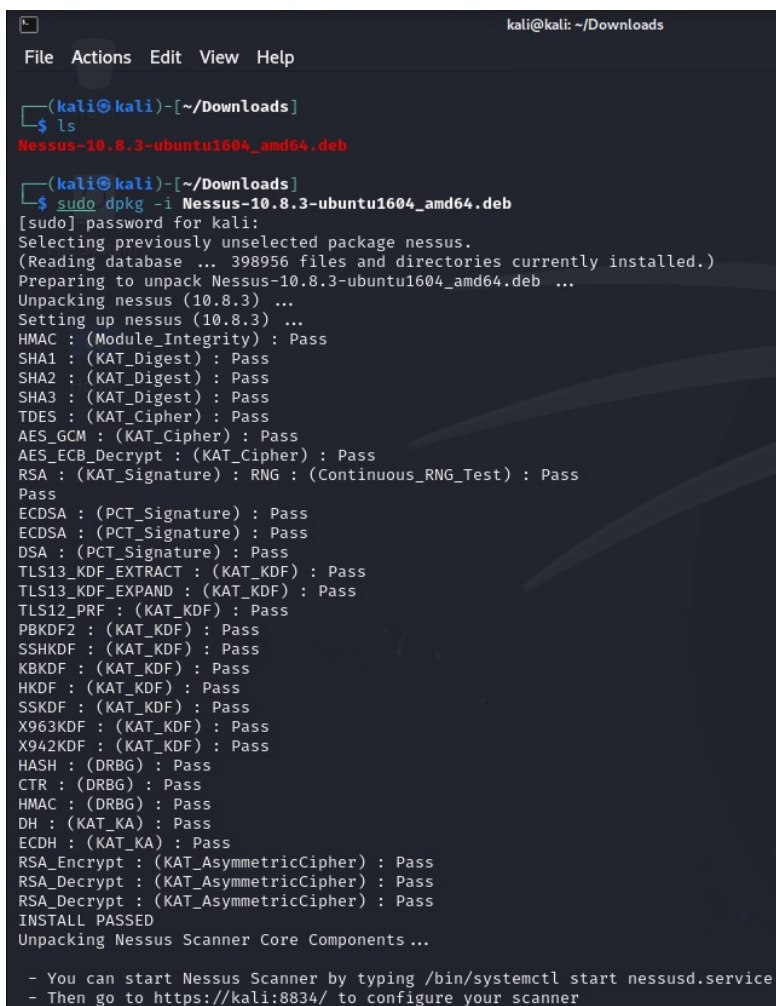
1. Descargar el instalador de Nessus desde la página oficial de Tenable.

<https://www.tenable.com/productos/nessus>.

Es necesario descargar la versión para Debian/Ubuntu, ya que Kali Linux está basado en Debian. El archivo tendrá la extensión “.deb”.

2. Una vez descargado, ingresamos a la carpeta en donde este alojado el archivo y abrimos el terminal para instalar el paquete e introducimos el siguiente comando:

```
sudo dpkg -i Nessus-10.8.3-ubuntu1604_amd64.deb
```



```
kali@kali: ~/Downloads
File Actions Edit View Help

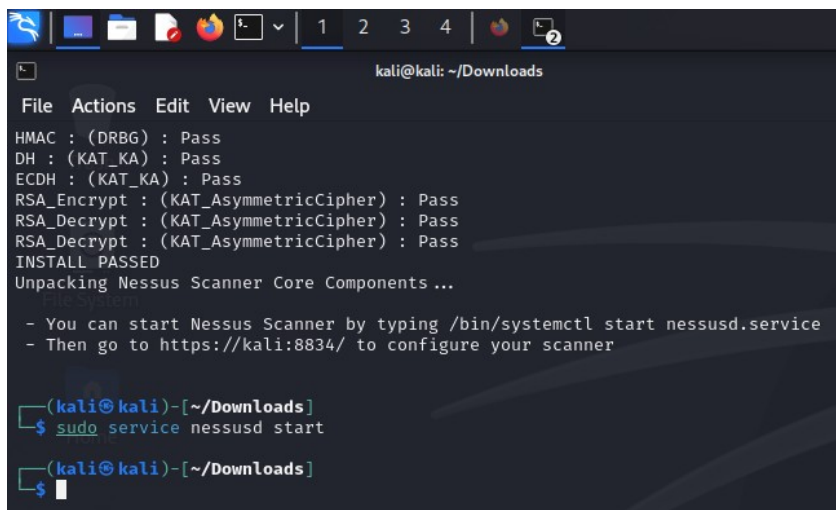
(kali@kali)-[~/Downloads]
$ ls
Nessus-10.8.3-ubuntu1604_amd64.deb

(kali@kali)-[~/Downloads]
$ sudo dpkg -i Nessus-10.8.3-ubuntu1604_amd64.deb
[sudo] password for kali:
Selecting previously unselected package nessus.
(Reading database ... 398956 files and directories currently installed.)
Preparing to unpack Nessus-10.8.3-ubuntu1604_amd64.deb ...
Unpacking nessus (10.8.3) ...
Setting up nessus (10.8.3) ...
HMAC : (Module_Integrity) : Pass
SHA1 : (KAT_Digest) : Pass
SHA2 : (KAT_Digest) : Pass
SHA3 : (KAT_Digest) : Pass
TDES : (KAT_Cipher) : Pass
AES_GCM : (KAT_Cipher) : Pass
AES_ECB_Decrypt : (KAT_Cipher) : Pass
RSA : (KAT_Signature) : RNG : (Continuous_RNG_Test) : Pass
Pass
ECDSA : (PCT_Signature) : Pass
ECDSA : (PCT_Signature) : Pass
DSA : (PCT_Signature) : Pass
TLS13_KDF_EXTRACT : (KAT_KDF) : Pass
TLS13_KDF_EXPAND : (KAT_KDF) : Pass
TLS12_PRF : (KAT_KDF) : Pass
PBKDF2 : (KAT_KDF) : Pass
SSHKDF : (KAT_KDF) : Pass
KBKDF : (KAT_KDF) : Pass
HKDF : (KAT_KDF) : Pass
SSKDF : (KAT_KDF) : Pass
X963KDF : (KAT_KDF) : Pass
X942KDF : (KAT_KDF) : Pass
HASH : (DRBG) : Pass
CTR : (DRBG) : Pass
HMAC : (DRBG) : Pass
DH : (KAT_KA) : Pass
ECDH : (KAT_KA) : Pass
RSA_Encrypt : (KAT_AsymmetricCipher) : Pass
RSA_Decrypt : (KAT_AsymmetricCipher) : Pass
RSA_Decrypt : (KAT_AsymmetricCipher) : Pass
INSTALL PASSED
Unpacking Nessus Scanner Core Components ...

- You can start Nessus Scanner by typing /bin/systemctl start nessusd.service
- Then go to https://kali:8834/ to configure your scanner
```

3. Iniciamos el servicio de Nessus con el siguiente comando en el terminal:

```
sudo systemctl start nessusd
```



```
kali@kali: ~/Downloads
File Actions Edit View Help
HMAC : (DRBG) : Pass
DH : (KAT_KA) : Pass
ECDH : (KAT_KA) : Pass
RSA_Encrypt : (KAT_AsymmetricCipher) : Pass
RSA_Decrypt : (KAT_AsymmetricCipher) : Pass
RSA_Decrypt : (KAT_AsymmetricCipher) : Pass
INSTALL PASSED
Unpacking Nessus Scanner Core Components ...

- You can start Nessus Scanner by typing /bin/systemctl start nessusd.service
- Then go to https://kali:8834/ to configure your scanner

(kali@kali)~[~/Downloads]
$ sudo service nessusd start

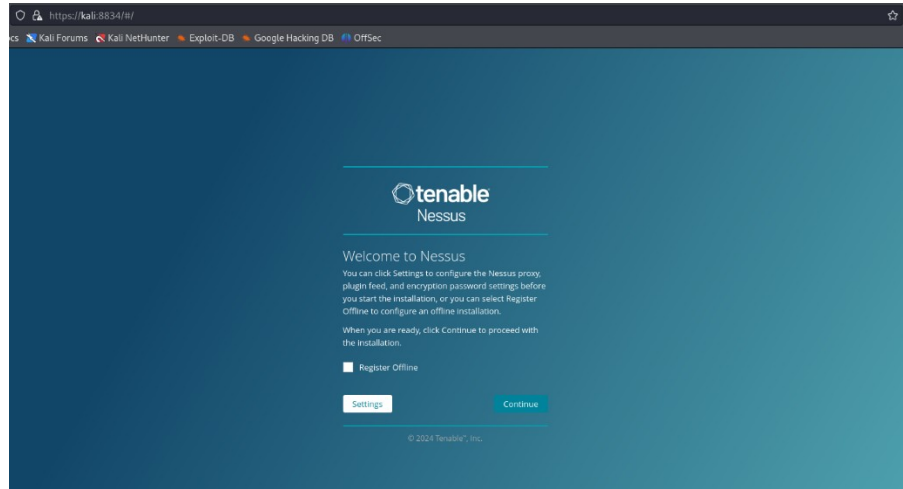
(kali@kali)~[~/Downloads]
$
```

Habilitamos la opción que se inicie automáticamente al arrancar el sistema operativo:

```
sudo systemctl enable nessusd
```

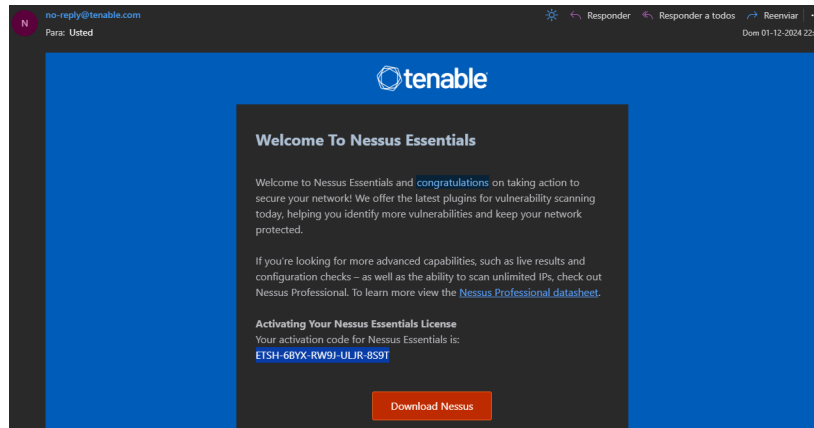
4. Accederemos a la interfaz web de Nessus ingresando en el navegador la siguiente url:

<https://kali:8834/>

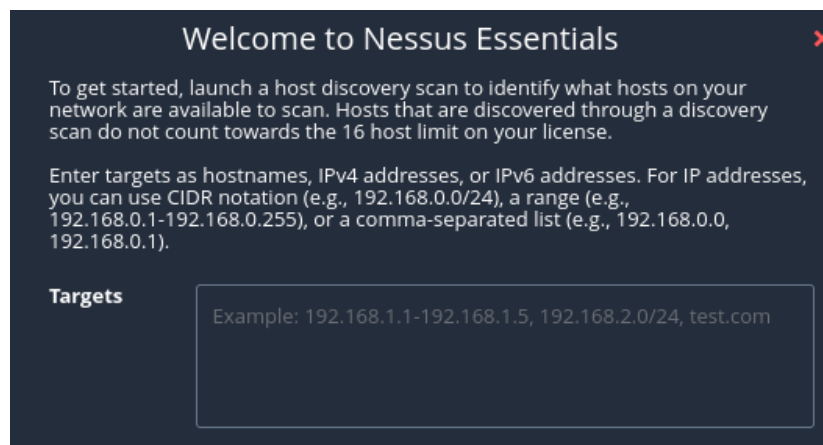


5. Configuración de Nessus:

- En esta oportunidad escogeremos el tipo de instalación gratuito **Nessus Essentials**.
- Para obtener una licencia gratuita, esta se obtiene en el sitio oficial de tenable.com, registrándose con un correo electrónico y contraseña. La licencia llegará al correo para ser ingresada en la interfaz de Nessus Essentials.
- Introduce la clave de activación para continuar con la configuración.



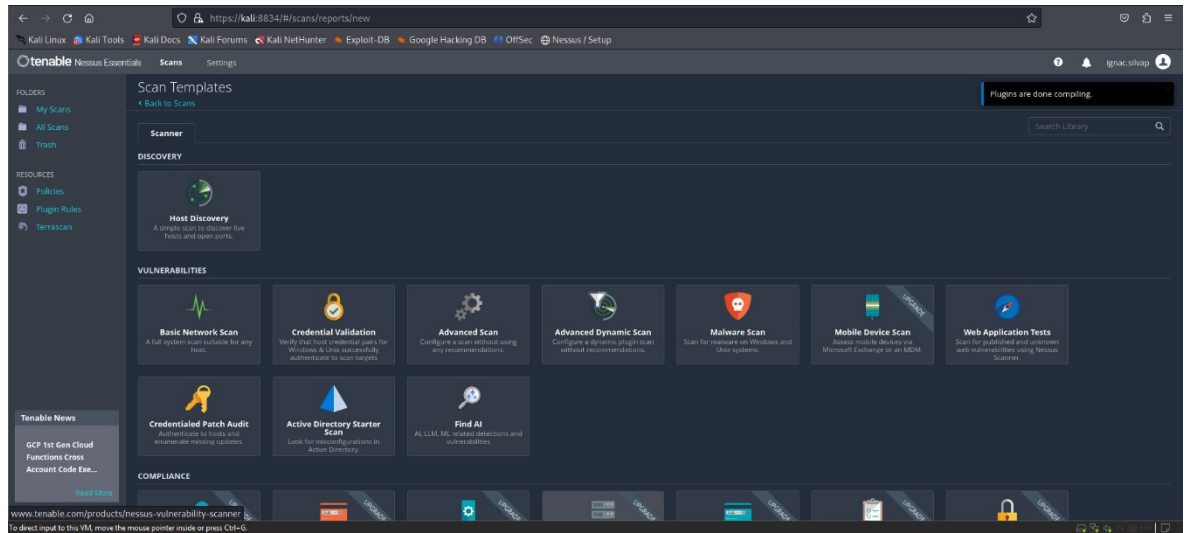
6. Durante la configuración inicial, Nessus descargará e instalará sus plugins.



7. Una vez finalizado, ya es posible utilizar Nessus Essentials para realizar escaneos seleccionando los objetivos y las plantillas desde la interfaz web.



UNIVERSIDAD
MAYOR
para espíritus emprendedores

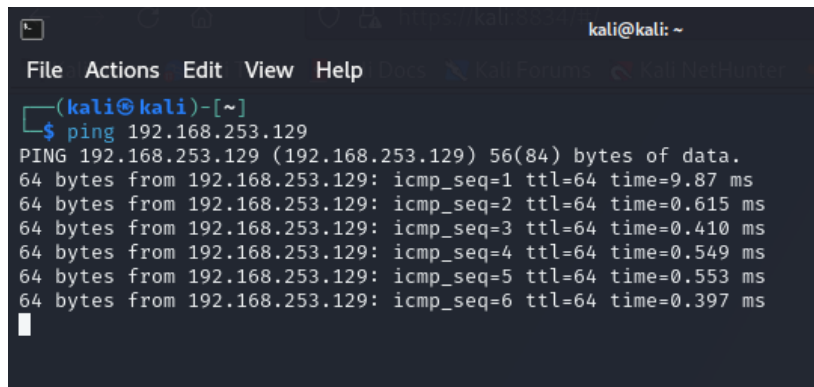


Escaneo de vulnerabilidades en Metasploitable 2.

IP de metasploitable2: 192.168.253.129

Para comenzar, verificamos que nuestro objetivo se encuentra conectado a la red y obtenemos respuesta ingresando el comando en el terminal:

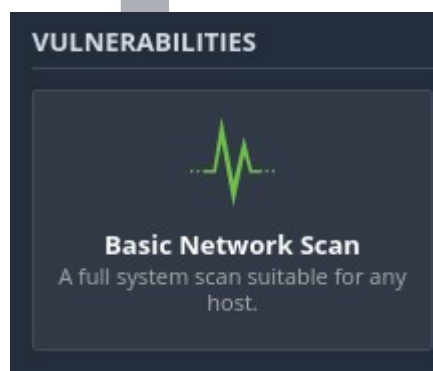
ping 192.168.253.129



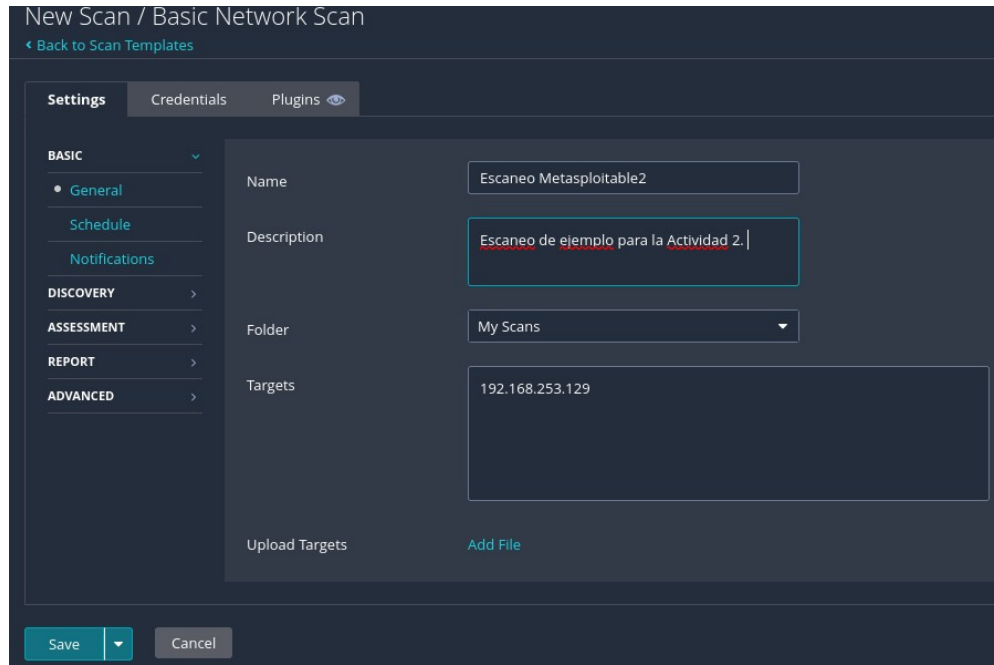
```
kali@kali: ~  
File Actions Edit View Help  
(kali@kali)-[~]  
$ ping 192.168.253.129  
PING 192.168.253.129 (192.168.253.129) 56(84) bytes of data.  
64 bytes from 192.168.253.129: icmp_seq=1 ttl=64 time=9.87 ms  
64 bytes from 192.168.253.129: icmp_seq=2 ttl=64 time=0.615 ms  
64 bytes from 192.168.253.129: icmp_seq=3 ttl=64 time=0.410 ms  
64 bytes from 192.168.253.129: icmp_seq=4 ttl=64 time=0.549 ms  
64 bytes from 192.168.253.129: icmp_seq=5 ttl=64 time=0.553 ms  
64 bytes from 192.168.253.129: icmp_seq=6 ttl=64 time=0.397 ms  
^
```

Seguiremos con la configuración del escaneo que le realizaremos a nuestro objetivo.

1. Crearemos un nuevo escaneo haciendo click en New Scan, posteriormente seleccionaremos la plantilla **Basic Network Scan**.



2. Configuramos el objetivo, en el campo Targets, ingresaremos la IP de Metasploitable2.
Se le asignara el nombre de “Escaneo Metasploitable2”.



New Scan / Basic Network Scan

< Back to Scan Templates

Settings Credentials Plugins

BASIC

- General
- Schedule
- Notifications

DISCOVERY >

ASSESSMENT >

REPORT >

ADVANCED >

Name: Escaneo Metasploitable2

Description: Escaneo de ejemplo para la Actividad 2.

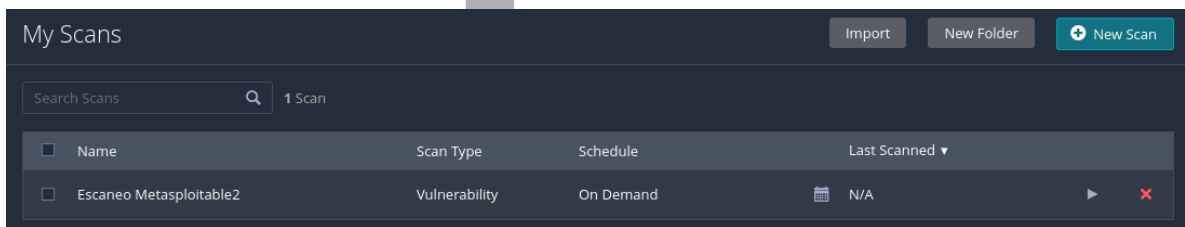
Folder: My Scans

Targets: 192.168.253.129

Upload Targets Add File

Save Cancel

3. Guardamos dando click en “Save” para guardar la configuración, y posteriormente en la lista de escaneos, buscamos el recién creado y ejecutamos para iniciar.



My Scans

Import New Folder New Scan

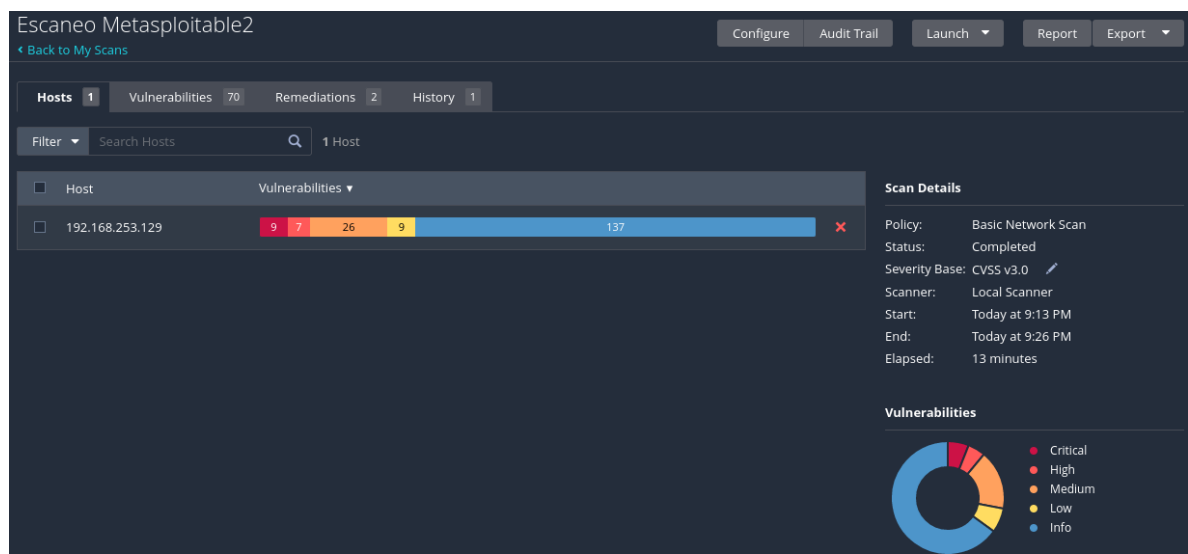
Search Scans 1 Scan

Name	Scan Type	Schedule	Last Scanned
Escaneo Metasploitable2	Vulnerability	On Demand	N/A

Resultados generales del escaneo a Metasploitable2.

Hemos identificado un total de 70 vulnerabilidades, y están clasificados por nivel de precaución.

- Críticas (Critical): 9 vulnerabilidades.
- Altas (High): 7 vulnerabilidades.
- Medias (Medium): 26 vulnerabilidades.
- Bajas (Low): 9 vulnerabilidades.
- Informativas (Info): 137 eventos, que no representan un riesgo directo.



La duración del escaneo fue de 13 minutos, esto indica que la red y los servicios han funcionado correctamente.

Análisis por nivel de severidad.

1. **Criticas (Critical):** estas vulnerabilidades severas permiten el acceso remoto o la explotación completa del sistema objetivo. Una acción recomendada es priorizar estas vulnerabilidades y aplicar parches o configuraciones sugeridas en el reporte (adjunto en carpeta de trabajo).
2. **Altas (High):** Son vulnerabilidades que indican riesgos serios que podrían ser explotados fácilmente. Algunos ejemplos de estas vulnerabilidades son SSH con claves débiles y servicios que permiten conexiones sin autenticación. Es necesario revisar y mitigar estas vulnerabilidades que después de abordar las criticas (Critical).
3. **Medias (Medium):** Estas podrían facilitar ataques, se requieren condiciones adicionales para ser explotadas. Por ejemplo, las configuraciones inseguras en MySQL o Apache.
4. **Bajas (Low):** Son problemas menores que tienen un impacto bajo en la seguridad y solo afectan configuraciones no esenciales. Por ejemplo, versiones desactualizadas de softwares.
5. **Informativas (Info):** No representan amenazas algunas, pero revelan detalles útiles como servicios detectados, puertos abiertos y configuraciones actuales.

Recomendaciones generales.

- Revisar vulnerabilidades críticas en detalles.
- Seguir un plan de remediación el cual se debe priorizar el orden:
“Criticas – Altas – Medias- Bajas”.
- Generar in informe completo utilizando la opción en Nessus “Export” es posible exportarlo en formato PDF.

Actividad 3.

OWASP ZAP

Para introducirnos en el mundo de la herramienta OWASP ZAP, debemos comprender que es esta herramienta y cómo funciona, según el siguiente autor describe lo siguiente:

“OWASP ZAP (ZEP ATTACK PROXY) es un escáner de aplicaciones web gratuito y de código abierto” (Van der Reijden, Lyons & Faure, 2014) *Owasp Testing Guide*.

Lo cual nos indica que su fuente se encuentra publica, también puede ser modificada y utilizada por cualquier persona o desarrollador que de igual manera puedan colaborar en la modificación de este software.

Esta herramienta logra identificar y corregir problemas en la seguridad de aplicaciones web, es utilizada para encontrar vulnerabilidades web por muchos expertos y novatos en el área de la ciberseguridad.

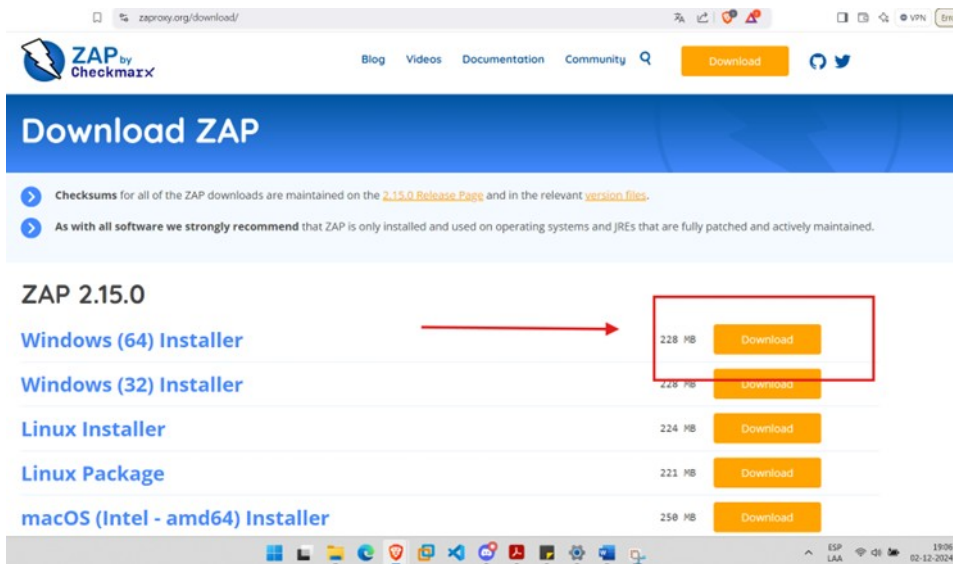
Dentro de sus principales características nombraremos las siguientes:

1. Interceptación proxy: el cual permite la interceptación y modificaciones de las solicitudes y respuestas HTTP Y HTTPS.
2. Escaneo automático: se pueden realizar escaneos automáticos con los cuales se buscarán vulnerabilidades en aplicaciones web.
3. Modo pasivo: detecta posibles solicitudes a las aplicaciones web
4. Modo activo: envía solicitudes específicas para probar la vulnerabilidad web de una aplicación.
5. Spidering: realiza una exploración automática a la estructura de la aplicación web.
6. Herramientas de exploración manual: es necesario que el usuario explore manualmente la aplicación web.
7. Integración con otros sistemas: tiene la versatilidad de integrarse a otras herramientas y plataformas web.

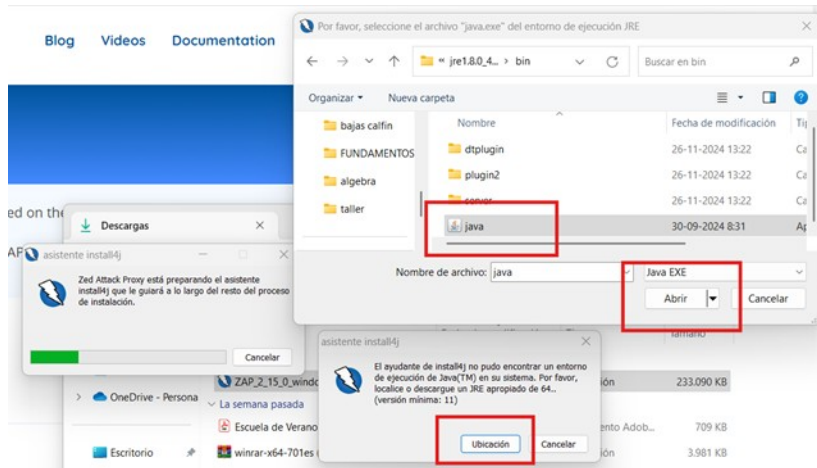
8. Actualizaciones y soporte continuo: es actualizable en el tiempo gracias a la comunidad de desarrolladores.

Instalación de OWASP ZAP

Procederemos a realizar la instalación de la herramienta OWASP ZAP desde su sitio oficial, realizaremos la instalación para Windows.



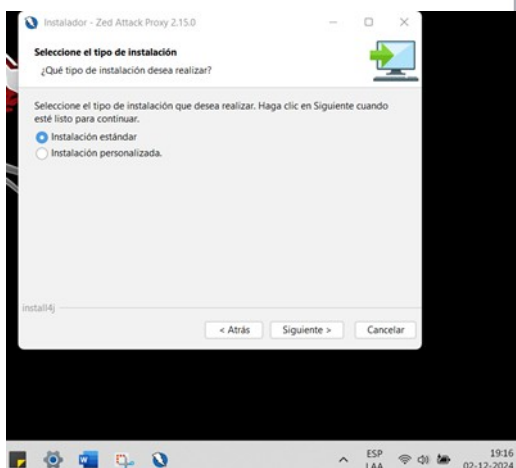
Dentro de la instalación procederemos a indicarle a la herramienta la ubicación de Java, la cual es solicitada dentro de la instalación como se muestra en la imagen.



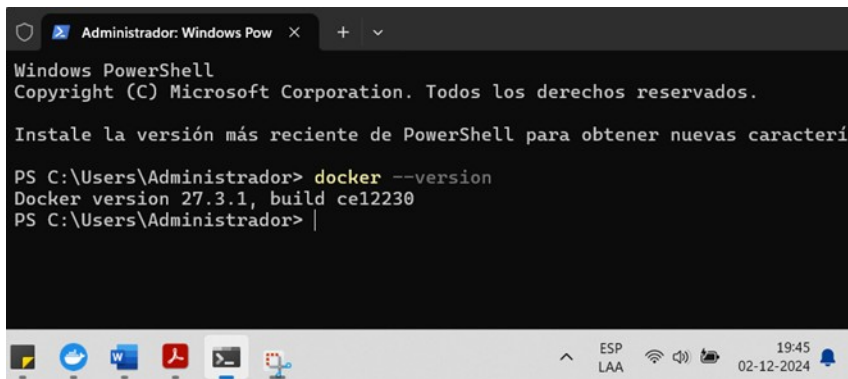
Se realiza la instalación de Java, la versión que solicita la herramienta.



Seleccionaremos la instalación estándar.



Ahora procederemos a realizar la configuración de Juice-shop utilizando Docker Compose para su ejecución, de esta manera levantaremos esta herramienta de prueba en un contenedor, revisaremos la versión de Docker que tenemos instalada y procederemos a correr Juice-shop en la PowerShell de Windows.

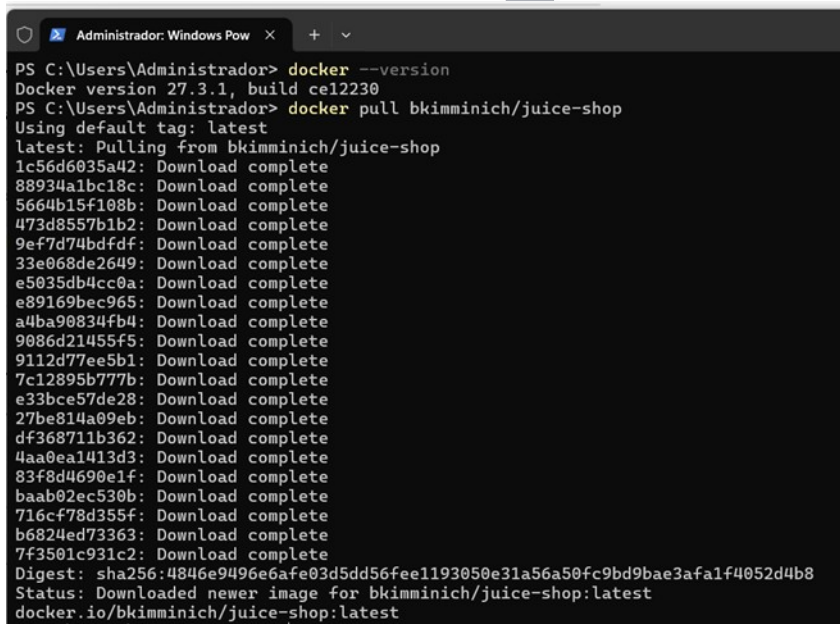


```
Administrador: Windows Pow x + v
Windows PowerShell
Copyright (C) Microsoft Corporation. Todos los derechos reservados.

Instale la versión más reciente de PowerShell para obtener nuevas caracteri

PS C:\Users\Administrador> docker --version
Docker version 27.3.1, build ce12230
PS C:\Users\Administrador> |
```

Con el comando “docker pull bkimminich/juice-shop” procederemos a instalar la versión más reciente de esta herramienta directamente desde Docker Hub.

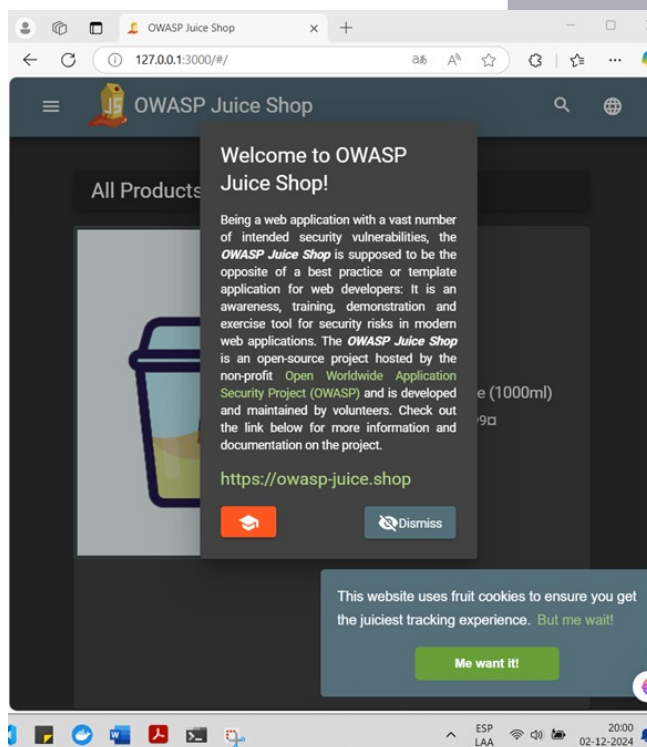


```
Administrador: Windows Pow x + v
PS C:\Users\Administrador> docker --version
Docker version 27.3.1, build ce12230
PS C:\Users\Administrador> docker pull bkimminich/juice-shop
Using default tag: latest
latest: Pulling from bkimminich/juice-shop
1c56d6035a42: Download complete
88934a1bc18c: Download complete
5664b15f108b: Download complete
473d8557b1b2: Download complete
9ef7d74bdfdf: Download complete
33e068de2649: Download complete
e5035db4cc0a: Download complete
e89169bec965: Download complete
a4ba90834fb4: Download complete
9086d21455f5: Download complete
9112d77ee5b1: Download complete
7c12895b777b: Download complete
e33bce57de28: Download complete
27be814a09eb: Download complete
df368711b362: Download complete
4aa0ea1413d3: Download complete
83f8d4690e1f: Download complete
baab02ec530b: Download complete
716cf78d355f: Download complete
b6824ed73363: Download complete
7f3501c931c2: Download complete
Digest: sha256:4846e9496e6afe03d5dd56fee1193050e31a56a50fc9b9bae3afa1f4052d4b8
Status: Downloaded newer image for bkimminich/juice-shop:latest
docker.io/bkimminich/juice-shop:latest
```

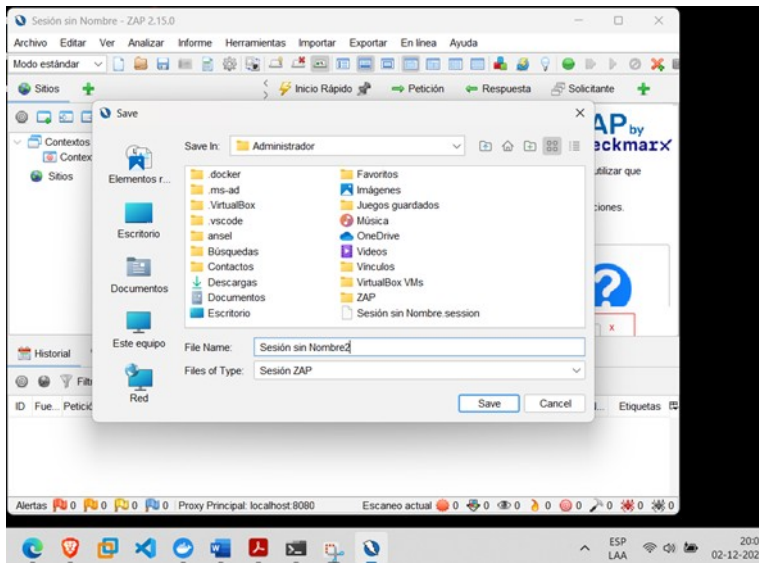
Con el siguiente comando “docker run --rm -p 3000:3000 bkimminich/juice-shop” podremos correr Juice-shop, mapeando el puerto 3000 del contenedor al puerto 3000 de la maquina local.

```
PS C:\Users\Administrador> docker run --rm -p 3000:3000 bkimminich/juice-shop
info: Detected Node.js version v20.17.0 (OK)
info: Detected OS linux (OK)
info: Detected CPU x64 (OK)
info: Configuration default validated (OK)
info: Entity models 19 of 19 are initialized (OK)
info: Required file server.js is present (OK)
info: Required file index.html is present (OK)
info: Required file styles.css is present (OK)
info: Required file polyfills.js is present (OK)
info: Required file main.js is present (OK)
info: Required file runtime.js is present (OK)
info: Required file vendor.js is present (OK)
info: Port 3000 is available (OK)
info: Chatbot training data botDefaultTrainingData.json validated (OK)
info: Domain https://www.alchemy.com/ is reachable (OK)
info: Server listening on port 3000
```

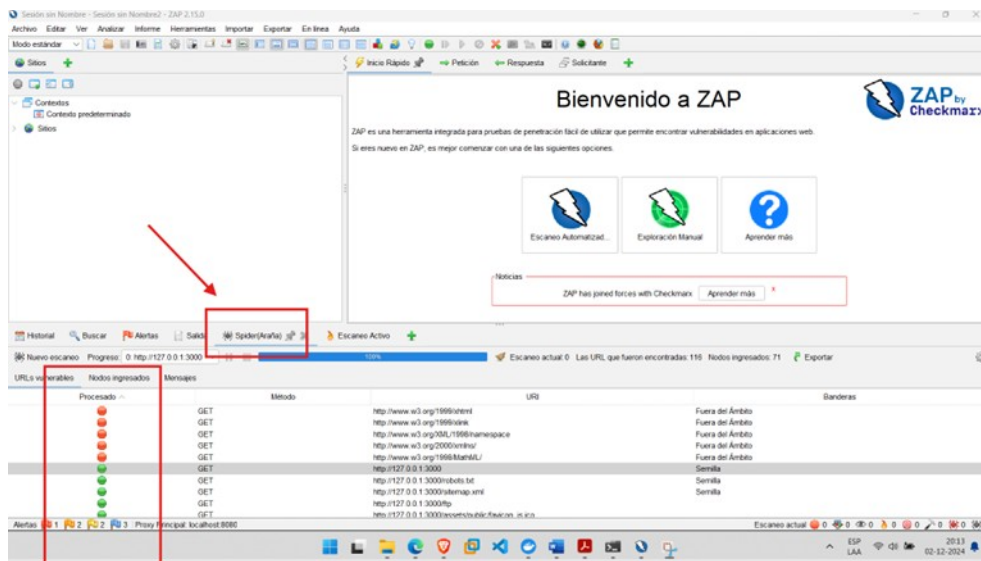
Una vez que logramos dejar en ejecución la herramienta Juice-shop mediante un contenedor, nos dirigiremos hasta el navegador e ingresaremos con la dirección ip local en el puerto 3000 “http://127.0.0.1:3000”, en donde nos abrirá la interfaz de OWASP JUICE-SHOP utilizada para realizar las pruebas en este informe.



Procederemos a iniciar la herramienta OWASP ZAP, la cual instalamos anteriormente, iniciaremos una sesión llamada “sin nombre2” y procederemos a guardarla.



Mediante el uso de OWASP ZAP se realizará un escaneo de seguridad automatizado de las aplicaciones y sitios web de la URL local entregada por Juice-shop, para esto utilizaremos una de las características automatizadas de esta herramienta, “spidering” la cual explora de manera automatizada la estructura de la aplicación web, de esta manera se pueden identificar sus páginas y recursos, cabe destacar que este escaneo automatizado muestra los hallazgos y los clasifica con colores, dando severidad a cada uno de ellos, el color rojo es alta severidad, el color amarillo es media severidad, color gris es informativa y el color verde es baja severidad.

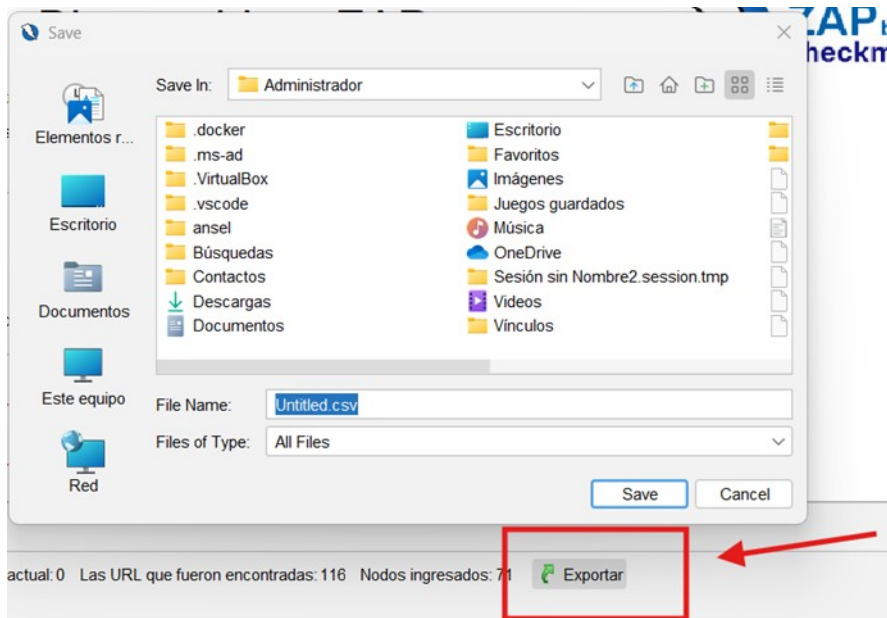


Análisis de resultados obtenidos

Como mencionamos anteriormente las vulnerabilidades están clasificadas en categorías

- **Alta (rojo):** Esto quiere decir que las vulnerabilidades críticas permiten comprometer el sistema, como por ejemplo la obtención de datos sensibles o llegar a tomar el control de estos servicios web.
- **Media (naranja):** Nos refleja problemas que pueden ser explotados en ciertas condiciones como por ejemplo cross-site scripting o (XSS) pudiendo un agente malicioso inyectar código malicioso en el recurso web.
- **Baja (amarilla):** Este color indica que alguna vulnerabilidad es menos probable que sea explotada como por ejemplo una versión desactualizada de software.
- **(Informativa)** informa acerca de alguna vulnerabilidad no crítica.

Procederemos a exportar los resultados para realizar un correcto análisis de lo obtenido.



3.2. Análisis de reporte generado

Sites: <http://cdnjs.cloudflare.com> <http://localhost:3000>

Generated on Mon, 2 Dec 2024 22:00:32

ZAP Version: 2.15.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	5
Low	4
Informational	3

Tras el escaneo se obtuvieron 12 alertas. Donde no hubo alertas de alto riesgo, hubo 54 alertas de riesgo medio, 4 alertas de riesgo bajo y 3 alertas informativas.

3.3 Detalle de las alertas presentadas

Alerts

Name	Risk Level	Number of Instances
Content Security Policy (CSP) Header Not Set	Medium	82
Cross-Domain Misconfiguration	Medium	100
Missing Anti-clickjacking Header	Medium	25
Session ID in URL Rewrite	Medium	105
Vulnerable JS Library	Medium	1
Cross-Domain JavaScript Source File Inclusion	Low	98
Private IP Disclosure	Low	1
Timestamp Disclosure - Unix	Low	5
X-Content-Type-Options Header Missing	Low	105
Information Disclosure - Suspicious Comments	Informational	4
Modern Web Application	Informational	50
Retrieved from Cache	Informational	12

3.3.1 Alertas de mediano riesgo

Las 5 alertas de mediano riesgo fueron:

- Content security policy header not set: Dicha alerta se detectó en 82 lugares dentro de la aplicación web. Esta alerta consiste en la falta de una política de seguridad de contenidos, esto, puede permitir la ejecución de scripts maliciosos.
- Cross Domain misconfiguration: Dicha alerta fue detectada en 100 lugares de la página web escaneada. Esta alerta, indica que existe un problema en la configuración pudiendo permitir que se ejecute un ataque de tipo XSS.
- Session ID in URL Rewrite: La alerta fue detectada en 105
- Descripción: Incluir identificadores de sesión en la URL puede comprometer la seguridad, ya que pueden ser fácilmente capturados.
- Vulnerable JS Library: Fue detectada por el uso de una biblioteca JavaScript vulnerable que posiblemente podría ser explotada por un atacante.

Alertas de Riesgo Bajo se enuncian a continuación:

- Cross-Domain JavaScript Source Inclusion: Se identifico la posibilidad de incluir scripts de origen cruzado, lo cual podría ser explotado si no se gestiona de manera adecuada. Se hallaron 98 instancias.
- Private IP Disclosure: Se detecto la divulgación de la dirección ip privada, lo que podría suponer un riesgo de seguridad. Se encontro1 caso de divulgación.
- Timestamp Disclosure – Unix: Se identificó información de marca de tiempo que podría proporcionar indicios sobre la infraestructura del sistema. Se encontraron 5 instancias.
- X-Content Type- Options Header Missing: La falta de este encabezado podría permitir que un navegador procese los documentos de forma incorrecta, lo que pone en riesgo la seguridad. Se detectaron 105 casos.

Alertas Informativas:

- Information Disclosure – Suspicious Comments: Comentarios en el código que podrían exponer información sensible. Se encontraron 4 instancias.
- Modern Web Application: Son atos generales sobre la aplicación web analizada. Se detectaron 50 casos informativos.
- Retrieved from Cache: Los datos extraídos de la caché, lo que podría indicar detalles sobre el almacenamiento de la información. Se identificaron 12 casos.

3.4. Se eligió la vulnerabilidad Cross-domain misconfiguration para ser buscada:

Se encontró que pertenece a la id de alerta 10098, de riesgo medio.

Esta vulnerabilidad consiste en que ocurren cuando una aplicación web permite solicitudes entre dominios sin una validación adecuada del origen. Esto puede llevar a que un atacante pueda realizar acciones no autorizadas, como robar información confidencial, a través de código JavaScript malicioso ejecutado en el navegador de la víctima. La causa principal de esta vulnerabilidad radica en las políticas de control de acceso permisivas implementadas por la aplicación web. *Cross-domain misconfiguration*. (s/f).

DOCUMENTOS > ALERTAS

Detalles	
Identificación de alerta	10098
Tipo de alerta	Pasivo
Estado	liberar
Riesgo	Medio
CWE	264
Asociación de Mujeres Comunitarias de Estados Unidos (WASC)	14
Tecnologías en el punto de mira	Todo
Etiquetas	CWE-264 OWASP_2017_A05 OWASP_2021_A01
Más información	Ayuda con las reglas de escaneo

Según CWE, esta vulnerabilidad pertenece a la identificación de categoría 264. Estando relacionada con la gestión de permisos y los privilegios de seguridad que son usados para realizar el control de acceso en dicha página web. Se adjunta imagen de referencia. (CWE - CWE-264 s.f)

CATEGORÍA CWE: Permisos, privilegios y controles de acceso

Identificación de la categoría: 264
Mapeo de vulnerabilidades: **PROHIBIDO**

Resumen
Las debilidades de esta categoría están relacionadas con la gestión de permisos, privilegios y otras características de seguridad que se utilizan para el acceso.

Afiliación

Naturaleza	Tipo	IDENTIFICACIÓN	Nombre
Miembro de	V	635	Debilidades utilizadas originalmente por NVD desde 2008 hasta 2016
Miembro de	C	1345	OWASP Top Ten 2021 Categoría A01:2021 - Control de acceso defectuoso

Segun el topten OWASP del 2021 esta vulnerabilidad esta encasillada en el A01-Broken Access control.

Dicha situación es provocada por fallas en los controles de acceso que subyace en la falla de políticas de control de acceso, provocando que se genere divulgación no autorizada de la información presente en la página, modificación y/o borrado de la información.

La cantidad de ocurrencias de esta vulnerabilidad asciende a más de 318.000 (*A01 broken access control - OWASP top 10:2021. s/f*).

owasp.org/Top10/A01_2021-Broken_Access_Control/

Los 10 mejores de OWASP: 2021

A01:2021 – Control de acceso averiado

Factores

CWE mapeados	Tasa de incidencia máxima	Tasa de incidencia promedio	Exploit ponderado promedio	Impacto ponderado promedio	Cobert máx
34	55,97%	3,81%	6.92	5,93	94,55

Descripción general

Desde la quinta posición, el 94 % de las aplicaciones se sometieron a pruebas para detectar algún tipo de control de acceso defectuoso, con una tasa de incidencia promedio del 3,81 %, y tiene la mayor cantidad de ocurrencias en el conjunto de datos aportado con más de 318 000. Las enumeraciones de debilidades comunes (CWE) notables incluidas son *CWE-200: Exposición de información confidencial a un actor no autorizado*, *CWE-201: Inserción de información confidencial en datos enviados* y *CWE-352: Falsificación de solicitud entre sitios*.

Tabla de contenidos

- Factores
- Descripción general
- Descripción
- Cómo prevenir
- Ejemplos de ataques
- Referencias
- Lista de CWE

Los 10 mejores de OWASP: 2021

- Hogar
- Aviso
- Introducción
- Cómo utilizar el OWASP Top 10 como estándar
- Cómo iniciar un programa de AppSec con OWASP Top 10
- Acerca de OWASP
- Lista de los 10 mejores del 2021
- A01 Control de acceso roto
- A02 Fallas criptográficas
- Inyección A03
- A04 Diseño inseguro
- A05 Configuración incorrecta de seguridad
- A06 Componentes vulnerables y obsoletos
- A07 Fallas de identificación y autenticación
- A08 Fallas de integridad de

3.5 Medidas de prevención:



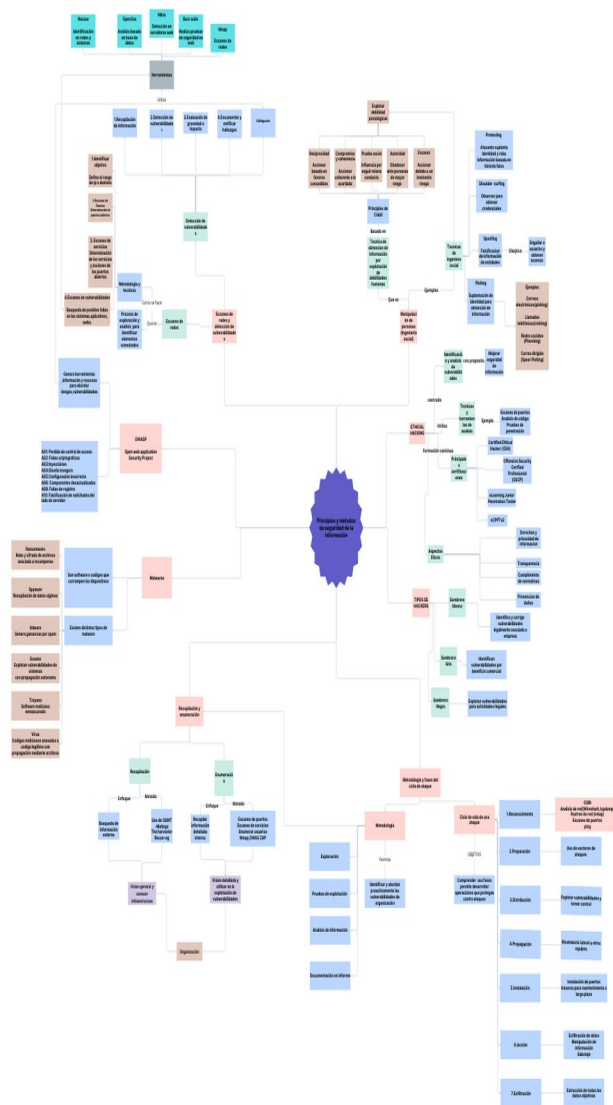
**UNIVERSIDAD
MAYOR**
para espíritus emprendedores

- Implementar controles de acceso más estrictos que impidan que el usuario edite registros.
- Tener herramientas que alerten de fallas de control de acceso y alerte de dichas fallas en tiempo real.
- Evitar la exposición de datos de la lista de directorios del servidor web.

4. Mapa conceptual



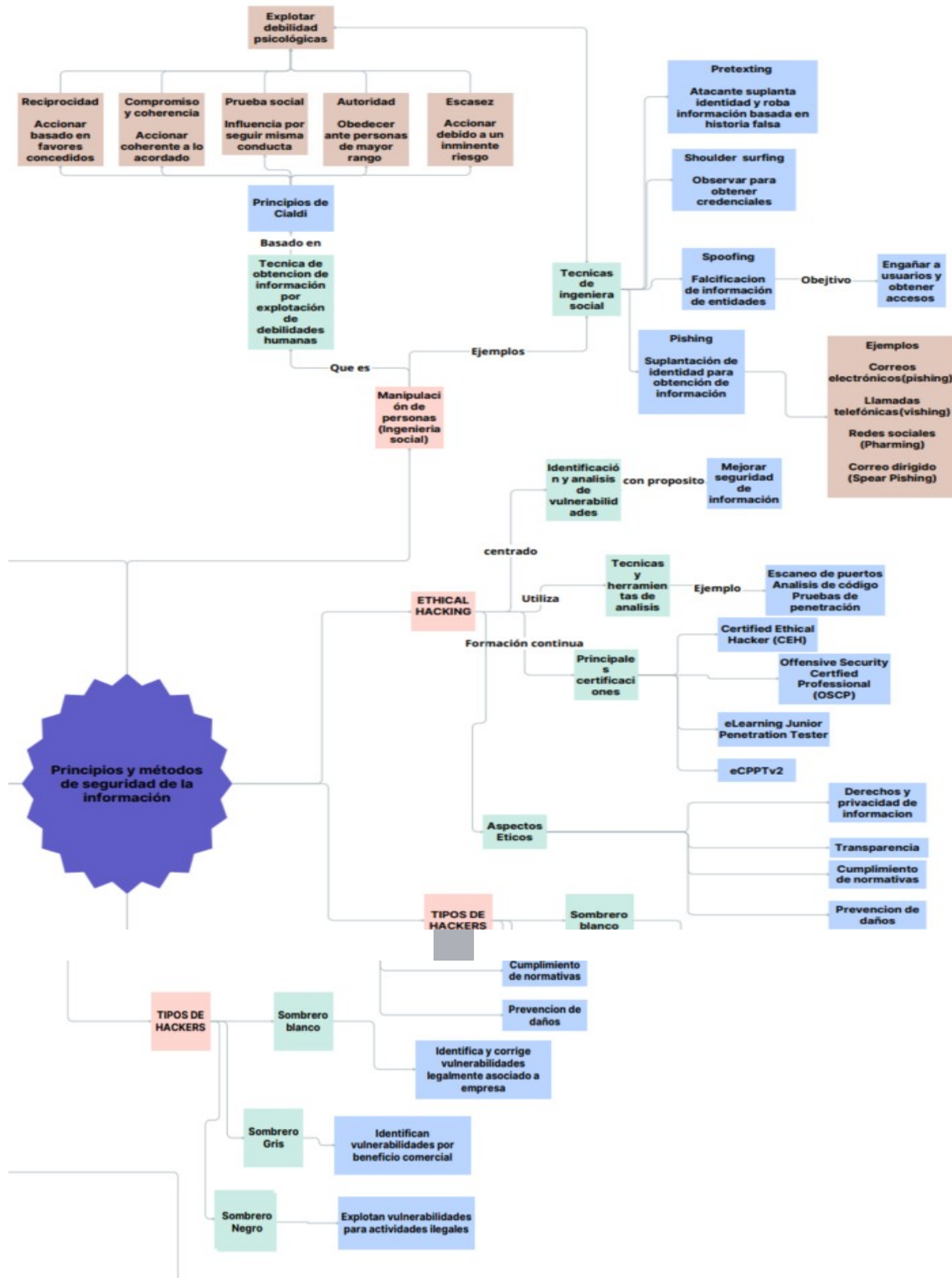
4.1 Imagen panorámica del mapa conceptual



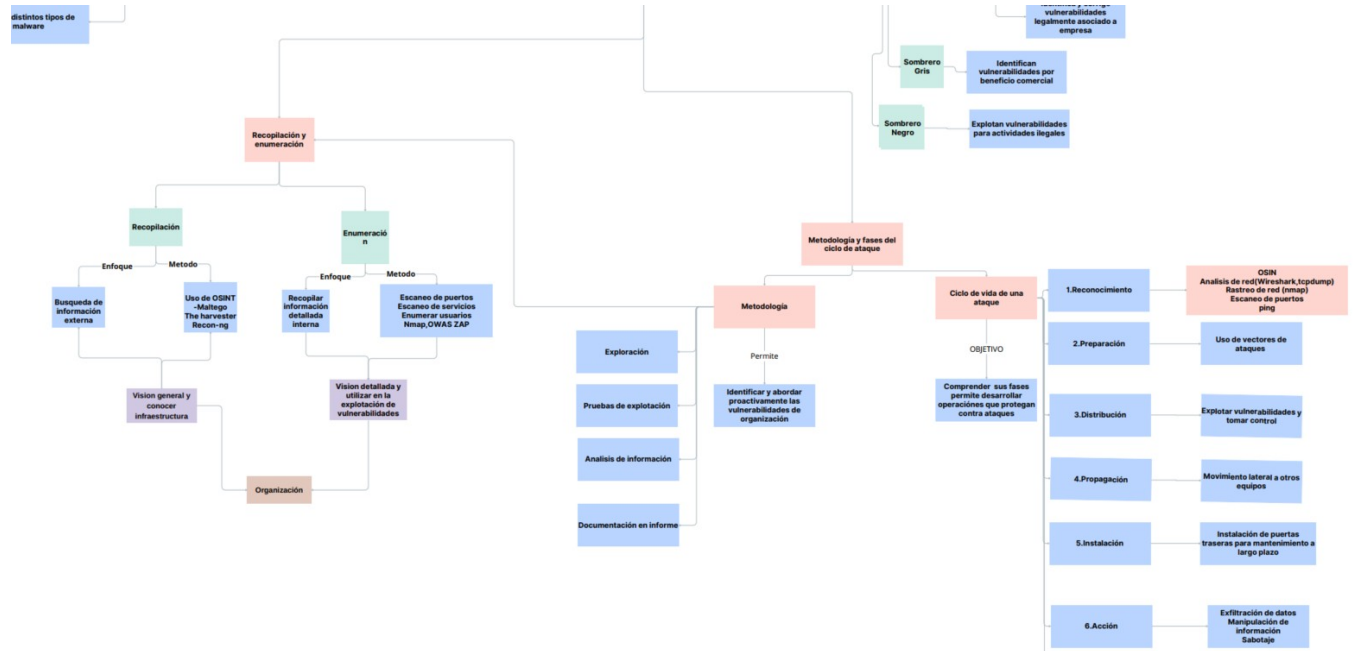
4.2 Imagen donde se observa tema central y temas principales basados en la pauta:



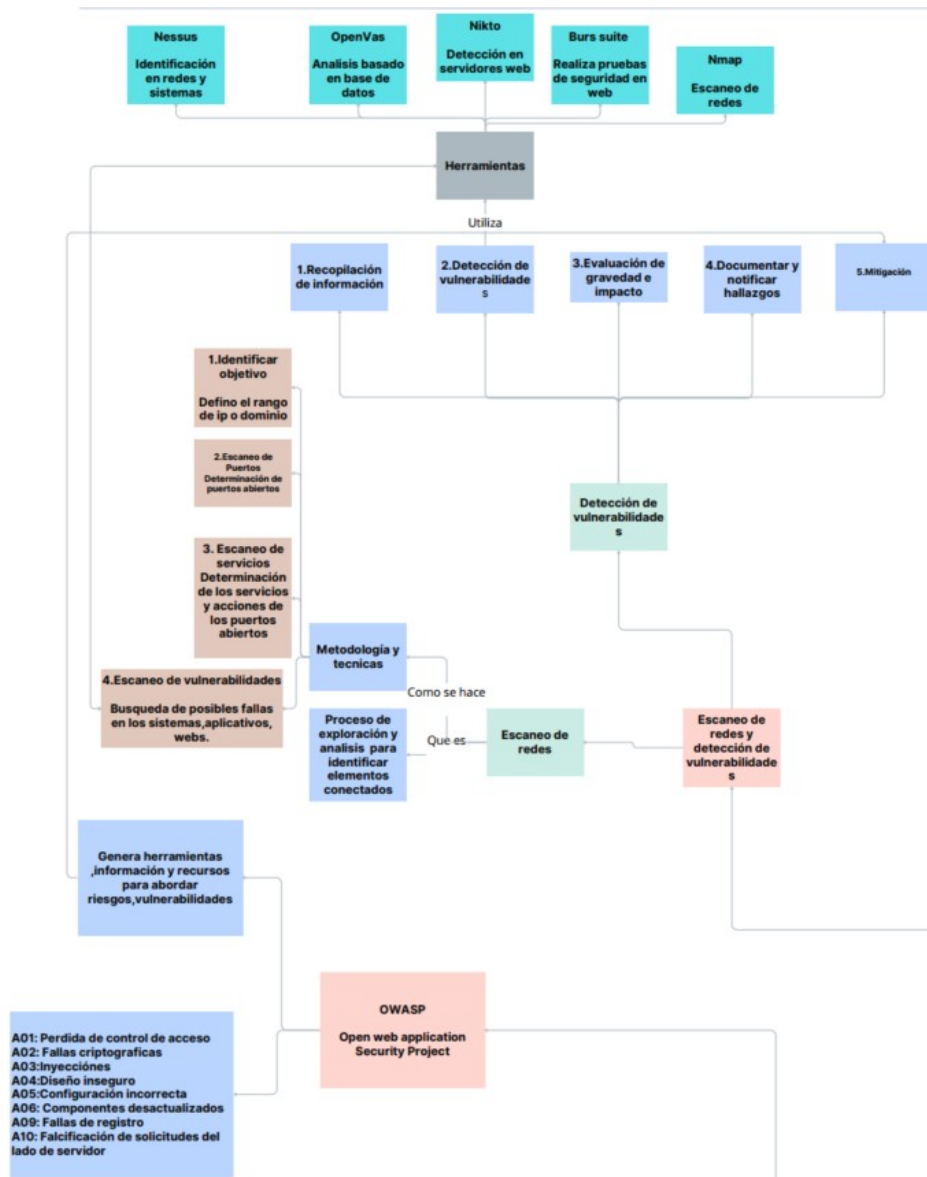
4.3 Imagen donde se observa manipulación de personas, ethical hacking y tipos de hackers



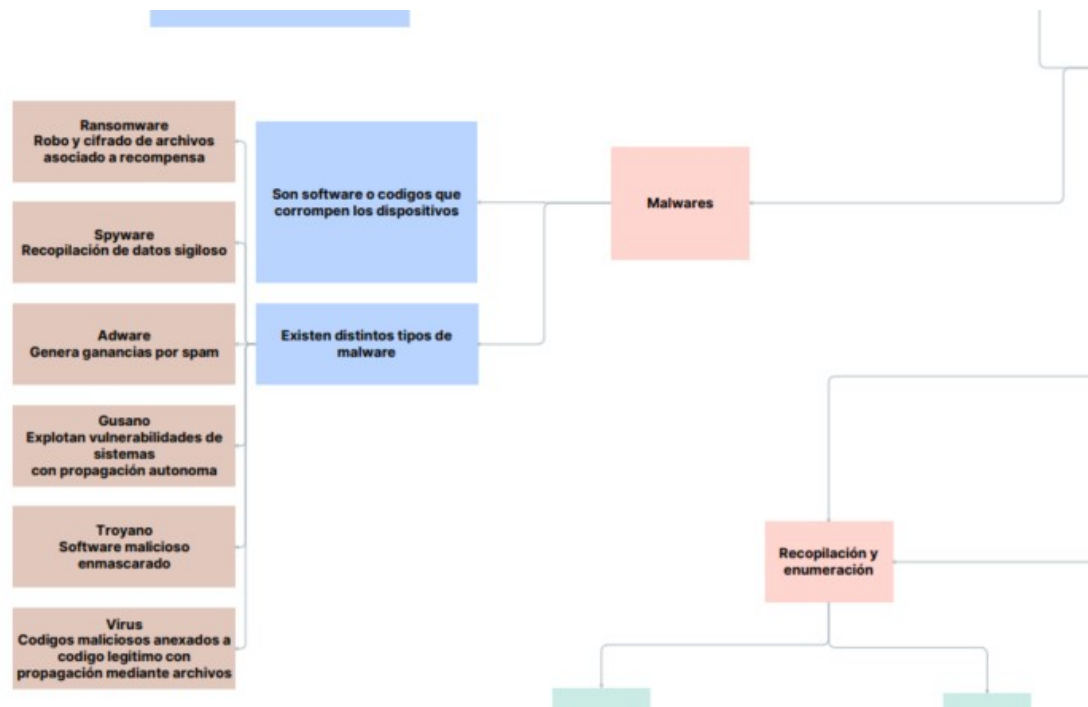
4.4. Imagen donde se observa temas de Reconocimiento -enumeración y metodologías y fases del ciclo de ataque.



4.5 Imagen donde se desarrollan temas de escaneo de redes, detección de vulnerabilidades y OWASP.



4.6 Imagen donde se desarrollan temas de Malware.



Conclusión

Como se pudo evidenciar en este trabajo, existen diversos métodos que nos permiten escanear redes y encontrar vulnerabilidades en sitios web, o aplicado a direcciones ip y redes específicas, dentro de las cuales tanto Nessus como también OWASP ZAP fueron de gran utilidad debido al detalle de los datos proporcionados para el análisis.

Bibliografía

1. *A01 broken access control - OWASP top 10:2021*. (s/f). Owasp.org. Recuperado el 3 de diciembre de 2024, de https://owasp.org/Top10/A01_2021-Broken_Access_Control/.
2. *Cross-domain misconfiguration*. (s/f). Zaproxy.org. Recuperado el 3 de diciembre de 2024, de <https://www.zaproxy.org/docs/alerts/10098/>.
3. *CWE - CWE-264: CWE CATEGORY: Permissions, privileges, and access controls (4.16)*. (s/f). Mitre.org. Recuperado el 3 de diciembre de 2024, de <https://cwe.mitre.org/data/definitions/264.html>.
4. Google. (2024), Google Search. Google. <https://www.google.cl>.

5. (Lyon, G, 2009), *Nmap Network Scanning*.
6. van der Reijden, A., Lyons, A., & Faure, D. R. (2014). *OWASP Testing Guide*.

